

AdvocateAuroraHealth

Title: AAH EA Standard		Document Number: 51928
Document Type: ☐ Policy ☐ Procedure ☐ Guideline ☒ Other Standard Work		Last Review/Revision Date: 12/16/2020
Content Applies to Patient Care: (Select all that apply) ☐ Adults ☐ Pediatrics (Under 18)	Content Applies to: (Select One) ☐ Clinical ☒ Administrative	Next Review Date: 12/16/2023 Effective Date: 12/16/2020
Scope: ☐ AAH System ☐ ACH ☐ AAH IL Only ☐ AAH WI Only ☐ Site Only (Location Name): ☐ Department Only (Department Name): Health Informatics & Technology (HIT)		

I. PURPOSE

To establish standards for all team members responsible for the Enterprise Architecture review process for Advocate Aurora applications and solutions.

II. SCOPE

This standard applies to the Health Informatics department within Advocate Aurora Health, Inc. and any or all Enterprise Architect reviews and processes maintained by the HIT department.

III. DEFINITIONS/ABBREVIATIONS

Advocate Aurora Information Resources: Any media, software, hardware or other technology that supports the use, access, processing, storage or transmission of Advocate Aurora Information.

Advocate Aurora Third Party (Third Party): Any person authorized to provide care or services at an Advocate Aurora Health facility who is not an employee of Advocate Aurora. This includes licensed independent practitioners, staff augmentation, volunteers, students, consultants, contractors, clinical observers and others.

Encryption: The process of converting information either in storage or in transit into an unintelligible form except to holders of a specific cryptographic key. Use

of encryption protects information between the encryption process and the decryption process (the inverse of encryption) against unauthorized disclosure.

End User Application: These are applications that are used by non-HIT personnel and are for configuring, patching or maintaining these applications. These would not be directly used by team members to perform healthcare functions. Examples would be network devices like routers or switches.

Host Based Firewall: Software which blocks unauthorized access to an endpoint while permitting outward communication.

Patch: A piece of software that is designed to update, fix, or improve another piece of software, supporting data, or operating system.

Server: A system (physical or virtual) device that provides access to a centralized resource or service across a network. This definition does not include containerization technologies.

Vulnerability: A weakness in the design, implementation, operation, or internal control of a process that could expose the system to adverse threats from threat events.

IV. STANDARDS

A. Active Directory Authentication (AD Authentication)

1. What is the standard: Azure AD would be the preferred solution with ADFS or LDAPS also being acceptable.
2. Why is it required: When a solution employs AD Authentication using Azure AD, ADFS or LDAPS, AAH personnel can terminate an account at a centralized location removing rights within 3rd party vendor solutions. AD authentication also removes account maintenance from local app teams (provides automation).

3. What is required? At the Intake process, it is noted if AD integration is available. Business office makes application owner aware all costs associated with AD integration and they are accepted by business. AD integration is validated during Risk Review processes. All “AD group” permission levels are activated when application account is activated. When an AD user account is no longer associated with application, it will automatically terminate. Any required AD integration with Cloud hosted or SaaS solutions must integrate into the enterprise ADFS solution utilizing SAML, OAuth or Relying Party Trusts.
4. Risk Treatment: LDAP is not allowed because it is not encrypted. Cloud or SaaS applications connectivity to directly access or query our enterprise Active Directory solution is not allowed. Use of local accounts will also need to be tracked on a quarterly schedule via Risk Management.

B. WEB Transport Layer Security

1. What is standard: All solutions that use a web browser for management or end user connectivity must enable TLS 1.2 or greater. This includes internal and external use of the web interface.
2. Why it is required: All web traffic must be encrypted with supported encryption technologies.
3. What is required: Web servers must be configured to restrict the use of any encryption options lower than TLS 1.2.
4. Risk Treatment: None

C. Vendor Remote Support

1. What is standard: Interactive maintenance or support done by a vendor must use SecureLink Enterprise with email MFA or SecureLink for Vendors.
2. Why is it required: SecureLink is an on-premise solution. This ensures that AAH has a record of vendor access and can access it through a central point.

3. What is required: Need to have the ability to record the sessions, have it documented, and be able to access it through an internal centralized point when needed.
4. Risk Treatment: Any vendors that are not able to use SecureLink will need to go through Risk Treatment.

D. Virtual hosts (preferred) or Physical Hosts

1. What is standard: Standard is to have HIT maintain a virtual host versus physical.
2. Why is it required: It is easier for maintenance and for disaster recovery (DR) purposes. Virtual hosts are easier to move between data centers. Physical hosts can get left behind (the hardware).
3. What is required: To use virtual hosts as first choice.
4. Risk Treatment: When unique hardware requirements or virtualization is an unnecessary use of resources.

E. Endpoint Protection

1. What is standard: Devices must use an AAH-provided endpoint protection solution. This includes either an Anti-Virus (AV) solution or an Endpoint Detection and Response (EDR) solution.
2. Why is it required: To protect AAH network from malware and viruses.
3. What is required: An endpoint protection solution.
4. Risk Treatment: AAH team members must demonstrate the exclusions are needed to solve a specific performance problem in our environment. Vendor documentation is not enough for exclusions to the standards scanning policies as you must show an actual impact in the AAH environment.

F. Endpoint Encryption

1. What is standard: Devices must use an AAH – approved endpoint encryption solution. This includes a solution to encrypt both at rest data on the hard drive, to external media.
2. Why is it required: To protect AAH data.
3. What is required: An endpoint encryption solution.

4. Risk Treatment: AAH team members must demonstrate the exclusions that are needed to solve a specific performance problem in our environment. Vendor documentation is not enough for exclusions to the standard encryption policies as you must show an actual impact in the AAH environment.

G. Browser Based Application

1. What is standard: AAH standard is Internet Explorer. Additionally, verify that the vendor can support both Edge (version 79.0.309 or greater) and Chrome.
2. Why is it required: Determining browser version dependencies ensures the most recent version update capability is always available keeping solution secure when launching the browser.
3. What is required: A minimum version number is required to determine if it would prevent future updating.
4. Risk Treatment: All non-standard Internet Browsers are required to be approved through Risk Treatment processes.

H. Thick Client Application

1. What is standard: Thick Client Applications are custom applications created by a vendor to handle local processing for their application or 3rd party frameworks that support other Thick Client Applications or Browser-based Application (i.e. Oracle Java, .NET framework)
2. Why is it required: The nature of server-based processing isn't optimal for a solution and a Thick Client Application's tighter integration with the user's device is required.
3. What is required: If the use of a Thick Client Application is required for the solution, AAH personnel will need to present the justification for the requirement. All Thick Client Applications installed on AAH devices must be packaged by AAH packaging teams. All connectivity to and from the Thick Client Application must be encrypted. A minimum version number for the Thick Client Application is required to determine if it would prevent future updating.

4. Risk Treatment: See supporting EA guideline for what may be considered for Risk Treatment.

I. Mobile Client

1. What is standard: Mobile Device Management (MDM) is required for all mobile devices connecting to the AAH production network. Personal devices are not allowed on any of the AAH production networks. AAH uses AirWatch for MDM.
2. Why is it required: To ensure that AAH mobile devices and associated ePHI are secure.
3. What is required: MDM for AAH mobile devices and the following:
 - a) Use Case and IT Security review is required and a ServiceNow ticket to "Mobility Request" must be submitted
 - b) It is recommended to select a device with the most current release date
4. Risk Treatment: If a mobile device cannot use our MDM, it will be placed on a firewalled wireless network to have limited (if any) Internet access and existing content filtering and geo fencing policies will still apply.

J. Patch Management

1. What is standard: Monthly patching must be done per [AAH Integrated Desktop/Laptop Security, and AAH Network Security, AAH Server Security Integrated, and Vulnerability Management Standard.](#)
2. Why is it required: To ensure that AAH desktop/laptop, mobile devices, servers and associated ePHI are secure.
3. What is required: Monthly patching must be done per [AAH Integrated Desktop/Laptop Security, and AAH Network Security, AAH Server Security Integrated, and Vulnerability Management Standard.](#)
4. Risk Treatment: Non-standard solutions must be behind a firewall with no Internet access and patches sourced from AAH resources. All deviations from standard must be tracked by HIT Security, Risk Management, and Governance.

K. Vulnerability Scanning and Remediation

1. What is standard: Vulnerability scans must occur at least monthly and on new assets, products and services prior to their go-live date.
2. Why is it required: To identify, classify, remediate, and/or mitigate vulnerabilities to prevent the possible exploitation of vulnerabilities that may exist within Advocate Aurora Information Resources.
3. What is required: Prior to go live, all high and critical vulnerabilities will be remediated or approved through risk treatment.
Vulnerabilities must be remediated per the [HIT Vulnerability Management Standard](#).
4. Risk Treatment: All non-standard patching processes will go through the risk treatment process.

L. Locality

1. What is standard: There is not a specific standard, please see requirements below for localities.
2. Why is it required: For Cloud, On Premise, and Hybrid: Locality choice will be fiscally responsible, and feature driven and follow the requirements below for each type of locality.
3. What is required: For Cloud, On Premise, and Hybrid solutions: They must all have data in transit encryption, AD Authentication (see above section 1), data at rest encryption. For cloud, it shall have SOC2 certification.
4. Risk Treatment: If unable to meet requirements, will need to request Risk Treatment.

M. Network

1. What is standard: All routers, switches, firewalls, and network support services (e.g. NTP, DNS, DHCP) will be provided and maintained by AAH team members.
2. Why is it required: To provide a high level of end to end network performance for solutions that are added to the AAH network, AAH team members need control and visibility to all aspects of the network.
3. What is required: Work with Network Engineering and Network Security for determining network requirements for your solution.

4. Risk Treatment: No network equipment is allowed that is non-AAH managed. In rare cases where a vendor-provided piece of network equipment is required, this will need to be reviewed by Network Engineering / Cyber Security and may require IT Compliance risk treatment.

N. Certificates

1. What is standard: All end user applications will have a non-self-signed certificate. PKI certificates are allowed for all non-internet facing devices. 3rd party certificates dedicated to specific hostname is recommended, wildcard certificates are not allowed. Self-signed certificates are allowed on non-end user applications like routers and switches.
2. Why is it required: Certificates allow user end points to determine if resources they are using on the AAH network or external networks are the servers we expect them to be. Errors and warnings that appear on your client or browser may indicate criminal activity.
3. What is required: Work with Network Security to secure a valid certificate for your solution.
4. Risk Treatment: No end user applications can use a self-signed certificate. Certificates need to either be signed by the AAH internal certificate authorities or the AAH managed 3rd party certificate authorities depending on the specific use case.

O. File Transfer

1. What is standard:
 - a. Internal/External MoveIT or GoAnywhere (IL) are the AAH standard for inbound and outbound file transfer.
 - b. Internal Only SFTP between endpoints that are both on the internal AAH network can use SFTP without the use of MoveIT or GoAnywhere. However, this solution does require Risk Treatment to document its use.

2. Why is it required: Whether an internal or external transfer, AAH requires file transfer protocols to be encrypted because of the sensitive nature of most of the data.
3. What is required: MoveIT, GoAnywhere,
4. Risk Treatment: All file transfers need to go through MoveIT or GoAnywhere team or it needs a Risk Treatment.

P. Business to Business VPN (B2B VPN)

1. What is standard: In cases, where a solution requires a network connection to another network then this is allowed for the following use cases:
 - a. The solution requires connectivity between endpoints on either side of the VPN where interactive logins are not required
 - b. LDAP was allowed prior to 1/1/2020 however is no longer acceptable
 - c. The solution provides 24x7 monitoring of endpoints on the AAH side of the VPN tunnel.
2. Why is it required: In cases, where a solution does not support encrypted Internet processing for the use cases above then a B2B VPN is an approved solution to force encryption for services that are not easily encrypted or are carrying sensitive data.
3. What is required: The Application owner must fill out and submit the [Advocate Aurora Network Security Request for New Site-to-Site \(B2B\) VPN Form](#) to Network Security.
4. Risk Treatment: Vendor remote support is not allowed as the sole use of a B2B VPN and AAH's vendor remote access SecureLink is required. However, if a B2B VPN is required for one of the use cases above, then interactive support is allowed over the B2B VPN.

Q. Operating System

1. What is standard: AAH will maintain the solution's operating system(s).
2. Why is it required: Vendors provide security improvements to their products often which may not be available for older operating systems.

3. What is required: The OS must be supported by the vendor. The latest operating system security patches must be up-to-date and maintained and follow vulnerability and patch management schedules.
4. Risk Treatment: Any deviations from this standard will require risk treatment.

V. **ROLES & RESPONSIBILITIES**

Role	Responsibility
Enterprise Architecture	Create, update, and maintain EA Standards for enterprise adoption and review annually
Solution Architecture	Enforce EA Standards
Application owners	Follow EA Standards and participate in Risk Remediation, and Risk Treatment processes where EA Standards aren't followed
CTO	Approve EA Standards for enterprise application
Risk Management	Risk Remediation and Risk Treatment processes where solutions cannot follow EA Standards

VI. **CROSS REFERENCES**

Advocate Aurora Health Care Policies:	Integrated Desktop/Laptop Policy Server Security Policy
Advocate Aurora Health Care HIT Standards:	Vulnerability Management standard

VII. **RESOURCES AND REFERENCES**

List of References:	Advocate Aurora Network Security Request for New Site-to-Site (B2B) VPN Form
----------------------------	--

Supported Compliance Controls:	NIST: 800-53, SA 3 CIS Control: # 3 Secure Configurations for Hardware and Software on Mobile Devices, Laptops, Workstations, and Servers #4 Continuous Vulnerability Assessment and Remediation #18 Application Software Security
---------------------------------------	---

VIII. APPENDICES

N/A